

IoT ATTACKS AND COUNTERMEASURES

IoT Concepts

The **Internet of Things (IoT)**, also known as the **Internet of Everything (IoE)**, refers to computing devices that are web-enabled and have the capability of sensing, collecting, and sending data using sensors, and the communication hardware and processors that are embedded within the device.

In the IoT, a “*thing*” refers to a device that is implanted in a natural, human-made, or machine-made object and has the functionality of communicating over a network. The IoT utilizes existing emerging technology for sensing, networking, and robotics, therefore allowing the user to achieve deeper analysis, automation, and integration within a system.

Some of the key features of the IoT are connectivity, sensors, artificial intelligence, small devices, and active engagement.

How the IoT Works

IoT technology includes four primary systems: IoT devices, gateway systems, data storage systems using cloud technology, and remote control using mobile apps. These systems together make communication between two (2) endpoints possible.

Here are some of the important components of IoT technology that play an essential role in the function of an IoT device:

- **Sensing Technology:** Sensors embedded in the devices sense a wide variety of information from their surroundings, including temperature, gases, location, workings of some industrial machinery, or health data of a patient.
- **IoT Gateways:** Gateways are used to bridge the gap between an IoT device (internal network) and the end-user (external network), thus allowing them to connect and communicate with each other. The data collected by the sensors in the IoT device is sent to the connected user or cloud through the gateway.
- **Cloud Server/Data Storage:** After traveling through the gateway, the collected data arrives at the cloud, where it is stored and undergoes data analysis. The processed data is then transmitted to the user, who can take certain actions based on the information received.
- **Remote Control using Mobile App:** The end-user uses remote controls such as mobile phones, tablets, laptops, etc., installed with a mobile app to monitor, control, retrieve data, and take a specific action on IoT devices from a remote location.

IoT Architecture

The IoT architecture includes several layers designed to meet the requirements of various sectors, including societies, industry, enterprises, governments, etc.

- **Edge Technology Layer**
This layer consists of all the hardware components, including sensors, radio-frequency identification (RFID) tags, readers, or other soft sensors, and the device itself. These entities are the primary part of the data sensors that are deployed in the field for monitoring or sensing various phenomena.

This layer plays an important part in data collection and in connecting devices within the network and with the server.

- **Access Gateway Layer**

This layer helps to bridge the gap between two endpoints, such as a device and a client. The initial data handling also takes place in this layer. This layer carries out message routing, message identification, and subscribing.

- **Internet Layer**

This is a crucial layer as it serves as the main component in carrying out communication between two endpoints, such as device-to-device, device-to-cloud, device-to-gateway, or back-end data sharing.

- **Middleware Layer**

This is one of the most critical layers that operates in two-way mode. As the name suggests, this layer sits in the middle of the application layer and the hardware layer, thus behaving as an interface between these two layers. It is responsible for important functions such as data management, device management, and various issues like data analysis, data aggregation, data filtering, device information discovery, and access control.

- **Application Layer**

This layer, placed at the top of the stack, is responsible for the delivery of services to the relevant users from different sectors, including building, industrial, manufacturing, automobile, security, and healthcare.

IoT Attacks

Challenges of IoT

To overcome significant issues, manufacturing companies should consider security as the top priority, starting with planning and design, and up to deployment, implementation, management, and maintenance.

Here are some of the challenges facing IoT devices that make them vulnerable to threats:

- Lack of Security and Privacy
- Vulnerable Web Interfaces
- Legal, Regulatory, and Rights Issues
- Default, Weak, and Hardcoded Credentials
- Clear Text Protocols and Unnecessary Open Ports
- Coding Errors (Buffer Overflow)
- Storage Issues
- Difficult-to-Update Firmware and OS
- Interoperability Standard Issues
- Physical Theft and Tampering
- Lack of Vendor Support for Fixing Vulnerabilities
- Emerging Economy and Development Issues
- Handling of Unstructured Data

OWASP Top 10 IoT Threats

The Top 10 IoT threats, according to the Open Web Application Security Project (OWASP), are listed below:

1. Weak, Guessable, or Hardcoded Passwords
2. Insecure Network Services
3. Insecure Ecosystem Interfaces
4. Lack of Secure Update Mechanisms
5. Use of Insecure or Outdated Components
6. Insufficient Privacy Protection
7. Insecure Data Transfer and Storage
8. Lack of Device Management
9. Insecure Default Settings
10. Lack of Physical Hardening

IoT devices have very few security protection mechanisms against various emerging threats. These devices can be infected by malware or malicious code at an alarming rate. Attackers often exploit these poorly

protected devices on the Internet to cause physical damage to the network, to wiretap the communication, and also to launch disruptive attacks such as DDoS.

Listed below are some types of **IoT Attacks**:

- **DDoS Attack:** An attacker converts the devices into an army of botnets to target a specific system or server, making it unavailable to provide services.

Given below are the steps followed by an attacker to perform a DDoS attack on IoT devices:

- Attacker gains remote access to vulnerable devices
- After gaining access, he/she injects malware into the IoT devices to turn them into botnets
- An attacker uses a command and control center to instruct botnets and to send multiple requests to the target server, resulting in a DDoS attack
- The target server goes offline and becomes unavailable to process any further requests

- **Attack on HVAC Systems:** As HVAC (Heating, Ventilation, and Air Conditioning) systems are generally connected to the networks of various industries, government sectors, and hospitals, their vulnerabilities are exploited by attackers to steal confidential information such as user credentials and to perform further attacks on the target network.
- **Rolling Code Attack:** The code that locks or unlocks a car or garage is called a **rolling code** or **hopping code**. It is used in a keyless entry system to prevent replay attacks. An eavesdropper can capture the code transmitted and later use it to unlock the garage or vehicle.

An attacker jams and sniffs the signal to obtain the code transferred to a vehicle's receiver; the attacker then uses it to unlock and steal the vehicle.

- **BlueBorne Attack:** Attackers connect to nearby devices and exploit the vulnerabilities of the Bluetooth protocol to compromise the devices. BlueBorne is a collection of various techniques based on the known vulnerabilities of the Bluetooth protocol.
- **Jamming Attack:** Jamming is a type of attack in which the communications between wireless IoT devices are jammed to compromise them. During this attack, an overwhelming volume of malicious traffic is sent, which results in a DoS attack to authorized users, thus obstructing legitimate traffic and making the endpoints unable to communicate with each other.
- **Remote Access using Backdoor:** Attackers exploit vulnerabilities in the IoT device to turn it into a backdoor and gain access to an organization's network.
- **Remote Access using Telnet:** Attackers exploit an open Telnet port to obtain information that is shared between the connected devices, including their software and hardware models.
- **Sybil Attack:** An attacker uses multiple forged identities to create a strong illusion of traffic congestion, affecting communication between neighboring nodes and networks.
- **Exploit Kits:** A malicious script is used by the attackers to exploit poorly patched vulnerabilities in an IoT device.
- **Man-in-the-Middle Attack:** An attacker pretends to be a legitimate sender who intercepts all the communication between the sender and receiver and hijacks the communication.
- **Replay Attack:** Attackers intercept legitimate messages from valid communication and continuously send the intercepted message to the target device to perform a denial-of-service attack or crash the target device.

- **Forged Malicious Device:** Attackers replace authentic IoT devices with malicious devices if they have physical access to the network.
- **Side-Channel Attack:** Attackers perform side-channel attacks by extracting information about encryption keys by observing the emission of signals, i.e., “side channels”, from IoT devices.
- **Ransomware Attack:** A type of malware that uses encryption to block a user’s access to his/her device, either by locking the screen or by locking the user’s files.
- **Client Impersonation:** An attacker masquerades as a legitimate smart device/server using a malicious device and compromises an IoT client device by impersonating it to perform unauthorized activities or access sensitive information on behalf of the legitimate client.
- **SQL Injection Attack:** Attackers perform SQL injection attacks by exploiting vulnerabilities in the mobile or web applications used to control the IoT devices, to gain access to the devices and perform further attacks on them.
- **SDR-Based Attack:** Using a software-based radio communication system, an attacker can examine the communication signals passing through the IoT network and can send spam messages to the interconnected devices.
- **Fault Injection Attack:** Also known as **perturbation attacks**, occurs when an attacker tries to introduce fault behavior in an IoT device, to exploit these faults to compromise the security of that device.

Here are the types of a fault injection attack:

- **Optical, Electromagnetic Fault Injection (EMFI), Body Bias Injection (BBI):** The main objective of these attacks is to inject faults into devices by projecting lasers and electromagnetic pulses that are used in analog blocks such as random number generators (RNGs) and for applying high-voltage pulses.
- **Power/Clock/Reset Glitching:** These types of attacks occur when faults or glitches are injected into the power supply that can be used for remote execution, also causing the skipping of key instructions. Faults can also be injected into the clock network used for delivering a synchronized signal across the chip.
- **Frequency/Voltage Tampering:** In these attacks, the attackers try to tamper with the operating conditions of a chip, and they can also modify the level of the power supply and alter the clock frequency of the chip. The intention of the attackers is to introduce fault behavior into the chip to compromise the device security.
- **Temperature Attacks:** Attackers alter the temperature for operating the chip, thereby changing the whole operating environment. This attack can be operated in non-nominal conditions.
- **Network Pivoting:** An attacker uses a malicious smart device to connect and gain access to a closed server, and then uses that connection to pivot other devices and network connections to the server to steal sensitive information.
- **DNS Rebinding Attack:** DNS rebinding is a process of obtaining access to a victim’s router using a malicious JavaScript code injected on a web page.

IoT Attack Countermeasures

Here are some of the IoT hacking tools used to exploit the target IoT devices and networks.

Firmalyzer

Enables device vendors and security professionals to perform an automated security assessment of the software that powers IoT devices (firmware) to identify configuration and application vulnerabilities. This tool notifies users about the vulnerabilities discovered and assists in mitigating those in a timely manner.

Below are some additional tools to perform IoT hacking:

- RIoT Vulnerability Scanner
- Foren6
- IoT Inspector
- RfCrack
- HackRF One

IoT Attack Countermeasures

Following these countermeasures, organizations can implement proper security mechanisms to protect the confidential information transmitted between the devices and the corporate network.

- Disable the “guest” and “demo” user accounts if enabled.
- Use the “Lock Out” feature to lock out accounts for excessive invalid login attempts.
- Implement a strong authentication mechanism.
- Locate control system networks and devices behind firewalls, and isolate them from the business network.
- Implement IPS and IDS in the network.
- Implement end-to-end encryption and use public key infrastructure (PKI).
- Use VPN architecture for secure communication.
- Deploy security as a unified, integrated system.
- Allow only trusted IP addresses to access the device from the Internet.
- Disable telnet (port 23).
- Disable the UPnP port on routers.
- Protect the devices against physical tampering.
- Patch vulnerabilities and update the device firmware regularly.
- Monitor traffic on port 48101, as infected devices attempt to spread the malicious file using port 48101.
- Position of mobile nodes should be verified with the aim of referring one physical node to one vehicle identity only, which means one vehicle cannot have two or more identities.
- Data privacy should be implemented; therefore, the user’s account or identity should be kept protected and hidden from other users.
- Data authentication should be performed to confirm the identity of the original source node.
- Maintain data confidentiality using symmetric key encryption.
- Implement a strong password policy requiring a password at least 8–10 characters long with a combination of letters, numbers, and special characters.
- Use CAPTCHA and account lockout policy methods to avoid brute-force attacks.
- Use devices made by manufacturers with a track record of security awareness.
- Isolate IoT devices on protected networks.

Reference:

EC-Council. (2021). *Ethical hacking essentials* (1st ed.). EC-Council.